多賣家電商平台 API 規格

> 狀態：定版
> 版本：1.2
> 最後更新：2026-10-15
> 依據：《需求_001_需求規格》1.8、《需求_002_使用者故事》1.6、《設計_004_資料庫設計》1.3、ADR_009、ADR_011、ADR_012

1. 範圍與檔案

本文件說明 API 的設計慣例、第一版範圍內的 API 清單，以及模擬金流的介面。每個 API 的欄位與回應細節，以 OpenAPI 規格檔為準：

規格檔	內容
`backend/spring-marketplace-app/src/main/resources/openapi/marketplace-api.yaml`	平台的 API
`backend/spring-mock-payment-gateway/src/main/resources/openapi/mock-payment-gateway-api.yaml`	模擬金流的 API

兩份規格檔是程式的來源：建置時以工具產生 Java 介面，程式實作這些介面（ADR_011）。應用程式啟動後以 Swagger UI 瀏覽，Swagger UI 直接讀取規格檔，不從程式反推。

規格檔以 tag 為 API 分組，命名為「使用對象-模組」，例如 `member-cart`、`seller-inventory`、`ops-account`；認證 API 為 `member-auth`、`seller-auth`、`ops-auth`，屬於帳號模組。每個 tag 產生一個 Java 介面，由該模組的控制器實作，因此一個介面不會跨越模組。

後續階段（出貨、退款、結算、搶購、折價券、報表）的 API，在各自的階段補充並升版。

2. 設計慣例

2.1 路徑

前綴	使用對象	驗證方式
`/api/v1/public`	任何人，包含訪客	不需要
`/api/v1/member`	會員	會員的存取權杖；註冊與登入除外
`/api/v1/seller`	賣家帳號	賣家帳號的存取權杖；登入除外
`/api/v1/ops`	營運帳號	營運帳號的存取權杖；登入除外
`/api/v1/webhooks`	模擬金流	回呼簽章

- 資源名稱用複數名詞與連字號，例如 `/shipping-addresses`

- 不屬於增刪改查的動作，以子路徑表示，例如 `POST /checkouts/{checkoutId}/cancel`
- 存取權杖的帳號類型必須與前綴相符，例如會員的權杖不能呼叫 `/api/v1/seller` 底下的 API

2.2 請求與回應

項目	規則
格式	JSON，欄位名稱用小駝峰
識別碼	UUID 字串
金額	整數，新臺幣元
比例	整數，萬分之一為單位
時間	ISO 8601，UTC，例如 `2026-10-14T06:30:00Z`；前端依需要換算成台灣時間
日期（查詢條件）	`YYYY-MM-DD`，以台灣日期解讀
空值	沒有值的欄位直接省略，不回傳 `null`

2.3 HTTP 狀態碼

狀態碼	使用時機
200	查詢成功；或重複送出的建立型請求，回傳第一次的結果
201	建立成功
204	成功且沒有回應內容，例如登出、刪除
400	請求格式或欄位驗證錯誤
401	未登入、權杖無效或過期、帳號或密碼錯誤、帳號鎖定
403	已登入但沒有權限
404	資源不存在，**或屬於其他會員或賣家**（不透露資源是否存在，需求 3.11、使用者故事 S1）
409	與目前狀態衝突，例如已有待付款結帳單、付款處理中
422	違反業務規則，例如庫存不足、商品已下架
429	超過請求頻率上限

2.4 錯誤回應

採用 RFC 9457 Problem Details，媒體類型為 `application/problem+json`：

`json { "type": "https://marketplace.example/errors/stock-insufficient", "title": "庫存不足", "status": 422, "detail": "部分商品的庫存不足", "code": "STOCK_INSUFFICIENT", "traceId": "4bf92f3577b34da6a3ce929d0e0e4736", "errors": [ { "field": "productId:0192f0c1-...", "message": "可購買數量為 2" } ] }`

- `code`：平台的錯誤代碼，前端依此顯示對應的訊息
- `traceId`：使用者回報問題時提供此值，即可查到完整的請求鏈路

- `errors`：欄位驗證錯誤或多筆資料的個別錯誤

第一版的錯誤代碼：

代碼	狀態碼	說明
`VALIDATION_FAILED`	400	欄位驗證錯誤
`UNAUTHENTICATED`	401	未登入或權杖無效
`INVALID_CREDENTIALS`	401	帳號或密碼錯誤
`ACCOUNT_LOCKED`	401	帳號暫時鎖定，回應附上解鎖時間
`TERMS_CONSENT_REQUIRED`	403	須先同意最新版本的條款
`PASSWORD_CHANGE_REQUIRED`	403	使用初始密碼登入，須先修改密碼
`FORBIDDEN`	403	沒有權限
`NOT_FOUND`	404	資源不存在或不屬於呼叫者
`USERNAME_TAKEN`	409	帳號名稱已被使用
`TERMS_NOT_LATEST`	422	同意的不是最新版本的條款
`COMMISSION_NOT_APPLICABLE`	422	平台自營賣家不設定抽成比例
`PENDING_CHECKOUT_EXISTS`	409	已有同類型的待付款結帳單
`IDEMPOTENCY_KEY_IN_USE`	409	相同冪等鍵的請求正在處理中
`IDEMPOTENCY_KEY_REUSED`	422	相同冪等鍵搭配了不同的請求內容
`CHECKOUT_NOT_PAYABLE`	409	結帳單已付款、已取消或已超過付款期限
`PAYMENT_IN_PROGRESS`	409	已有處理中的付款
`CHECKOUT_NOT_CANCELLABLE`	409	結帳單不是待付款，或有成功、處理中的付款
`PRODUCT_UNLISTED`	422	商品已下架
`STOCK_INSUFFICIENT`	422	庫存不足
`QUANTITY_LIMIT_EXCEEDED`	422	單一商品超過 99 件
`INVALID_STOCK_ADJUSTMENT`	422	庫存調整後會小於零
`RATE_LIMITED`	429	超過請求頻率上限
`INVALID_SIGNATURE`	401	金流回呼的簽章無效或已過期
`UNSUPPORTED_REQUEST`	405、406、415	不支援的 HTTP 方法、回應格式或請求的媒體類型
`INTERNAL_ERROR`	500	未預期的系統錯誤；回應不含錯誤細節，以 `traceId` 查詢日誌

2.5 分頁

參數	說明
`page`	從 1 開始，預設 1
`size`	20、50、100，預設 20；其他數值回應 400
`from`、`to`	日期區間；資料量會持續增長的列表必填或使用預設值（需求 3.11）

分頁回應的格式：

`json { "items": [], "page": { "page": 1, "size": 20, "totalItems": 10000, "totalItemsCapped": true, "totalPages": 500 } }`

`totalItemsCapped` 為 `true` 時表示實際筆數超過上限，`totalItems` 只計算到上限。

2.6 冪等鍵

適用於：建立結帳單、發起付款。日後的申請退款、搶購的立即購買也適用。

情況	回應
第一次送出	正常處理，回應 201
相同冪等鍵、相同內容，第一次已完成	回應 200 與第一次的結果，不重複處理
相同冪等鍵、相同內容，第一次仍在處理中	409 `IDEMPOTENCY_KEY_IN_USE`，用戶端稍後重試
相同冪等鍵、不同內容	422 `IDEMPOTENCY_KEY_REUSED`

- 冪等鍵由用戶端產生，建議使用 UUID，長度上限 100 字元
- 冪等鍵的範圍是「同一位會員」，不同會員使用相同的值互不影響
- 是否「相同內容」以請求內容的雜湊值判斷，與冪等鍵一起保存

2.7 認證流程

步驟	API	說明
登入	`POST /api/v1/{member,seller,ops}/auth/login`	回應內容帶存取權杖；更新權杖以 Cookie 設定
呼叫 API	任何需要驗證的 API	`Authorization: Bearer <存取權杖>`
換發	`POST /api/v1/{member,seller,ops}/auth/refresh`	瀏覽器自動帶上更新權杖的 Cookie；回應新的存取權杖，並以 Cookie 設定新的更新權杖
登出	`POST /api/v1/{member,seller,ops}/auth/logout`	撤銷更新權杖並清除 Cookie
修改密碼	`POST /api/v1/{member,seller,ops}/auth/password`	需提供目前的密碼；成功後撤銷該帳號所有更新權杖（ADR_009），須重新登入

更新權杖的 Cookie：名稱 `refresh_token`，`HttpOnly`、`Secure`、`SameSite=Strict`，`Path` 限定在對應前綴的 `/auth` 路徑。`SameSite=Strict` 同時防止其他網站利用這個 Cookie 發出偽造的換發請求。

由營運管理者建立的賣家帳號與營運帳號帶有初始密碼，第一次登入後呼叫其他 API 時回應 403 `PASSWORD_CHANGE_REQUIRED`，修改密碼後才能使用。

各步驟的細節：

項目	規則
登入失敗	帳號不存在、密碼錯誤、帳號停用、所屬賣家停用，一律回應 401 `INVALID_CREDENTIALS`，不透露帳號是否存在；帳號鎖定時回應 401 `ACCOUNT_LOCKED` 與 `lockedUntil`
帳號類型	帳號只能從自己類型的前綴登入；更新權杖也只能在發出它的前綴換發
同時換發	同一個更新權杖同時被用來換發時，只有一個請求成功，其餘視為重複使用，撤銷該帳號所有更新權杖（《設計_004_資料庫設計》3）。前端應避免同時發出多個換發請求
登出	只需要更新權杖的 Cookie，不需要存取權杖；撤銷的是該帳號在所有裝置上的更新權杖（ADR_009）。權杖無效時同樣回應 204 並清除 Cookie
修改密碼	目前的密碼錯誤回應 401 `INVALID_CREDENTIALS`；新密碼與目前的密碼相同回應 400 `VALIDATION_FAILED`

條款更新後尚未同意的帳號，呼叫需要身分的 API 時回應 403 `TERMS_CONSENT_REQUIRED`；登入、同意條款、查詢條款的 API 不受此限制（需求 3.12）。

2.8 規則告知所需的資料

需求 3.12 要求提醒文字中的數值取自系統設定。由以下方式提供：

- `GET /api/v1/public/rules`：回應付款期限、單一商品上限、即將售完門檻等設定值
- 有期限的事項在回應中帶確切時間，例如結帳單的 `paymentDeadline`

3. 第一版的 API

標註「故事」欄的對應《需求_002_使用者故事》。

3.1 公開

方法與路徑	用途	故事
`GET /api/v1/public/rules`	規則告知用的設定值	N2
`GET /api/v1/public/categories`	分類清單	
`GET /api/v1/public/products`	分類瀏覽與關鍵字搜尋，可依價格區間篩選、依上架時間或價格排序	Q1
`GET /api/v1/public/products/{productId}`	商品頁，含庫存狀態	Q2

方法與路徑	用途	故事
`GET /api/v1/public/terms/{documentType}/latest`	最新版本的條款	N1

第一版的商品查詢直接查資料庫，依銷量排序與搜尋引擎留到讀取效能階段。

3.2 會員

方法與路徑	用途	故事
`POST /api/v1/member/auth/register`	註冊，須同時同意服務條款與隱私權政策	N1
`POST /api/v1/member/auth/login`	登入	A1
`POST /api/v1/member/auth/refresh`	換發存取權杖	
`POST /api/v1/member/auth/logout`	登出	
`POST /api/v1/member/auth/password`	修改密碼	
`POST /api/v1/member/terms-consents`	同意新版本的條款	N1
`GET`、`POST /api/v1/member/shipping-addresses`	收件資訊清單、新增	
`PUT`、`DELETE /api/v1/member/shipping-addresses/{addressId}`	修改、刪除	
`GET /api/v1/member/cart`	購物車，含目前價格、庫存狀態與是否超過結帳上限	
`PUT /api/v1/member/cart/items/{productId}`	加入購物車或修改數量，數量 1 到 99	
`DELETE /api/v1/member/cart/items/{productId}`	從購物車移除	
`POST /api/v1/member/checkouts`	結帳，可只結帳購物車中的部分商品；需冪等鍵	O1、O2、O3
`GET /api/v1/member/checkouts`	我的訂單列表	Q3
`GET /api/v1/member/checkouts/{checkoutId}`	訂單詳情	Q3
`POST /api/v1/member/checkouts/{checkoutId}/cancel`	主動取消	O6
`POST /api/v1/member/checkouts/{checkoutId}/payments`	發起付款；需冪等鍵	P1、P5
`GET /api/v1/member/checkouts/{checkoutId}/payments/latest`	查詢最新一筆付款的結果，由付款模組直接回答	Q5

收件資訊的刪除以標記方式處理，已建立的結帳單保存的是快照，不受影響。

購物車的數量可能因取消後放回而超過 99 件（需求 3.1），此時該項目帶有 `exceedsCheckoutLimit: true`；結帳時包含這類項目回應 422 `QUANTITY_LIMIT_EXCEEDED`。會員以 `PUT` 改為 99 件以下即可結帳。

3.3 賣家

方法與路徑	用途	權限
`POST /api/v1/seller/auth/login`、`refresh`、`logout`、`password`	認證與修改密碼	
`POST /api/v1/seller/terms-consents`	同意賣家條款	管理者
`GET`、`POST /api/v1/seller/products`	商品列表、新增商品	管理者、一般成員
`GET`、`PUT /api/v1/seller/products/{productId}`	商品詳情、修改	管理者、一般成員
`POST /api/v1/seller/products/{productId}/list`	上架	管理者、一般成員
`POST /api/v1/seller/products/{productId}/unlist`	下架	管理者、一般成員
`GET /api/v1/seller/products/{productId}/stock`	庫存數字	管理者、一般成員
`GET /api/v1/seller/products/{productId}/stock/movements`	庫存異動紀錄	管理者、一般成員
`POST /api/v1/seller/products/{productId}/stock/inbound`	入庫	管理者、一般成員
`POST /api/v1/seller/products/{productId}/stock/adjustments`	調整庫存	管理者、一般成員
`GET /api/v1/seller/orders`	子訂單列表	管理者、一般成員
`GET /api/v1/seller/orders/{sellerOrderId}`	子訂單詳情	管理者、一般成員

賣家管理者管理底下帳號的 API（需求 3.13）不在第一版的流程中，留到出貨與退款階段一併補上。

3.4 平台營運

方法與路徑	用途	權限
`POST /api/v1/ops/auth/login`、`refresh`、`logout`、`password`	認證與修改密碼	
`GET`、`POST /api/v1/ops/sellers`	賣家列表；建立賣家與其第一個管理者帳號	查詢：所有角色；建立：營運管理者
`GET /api/v1/ops/sellers/{sellerId}`	賣家詳情	所有角色
`PUT /api/v1/ops/sellers/{sellerId}/commission-rate`	設定抽成比例	營運管理者

方法與路徑	用途	權限
`POST /api/v1/ops/categories`	新增分類	營運管理者
`POST /api/v1/ops/terms-documents`	發布條款新版本	營運管理者
`GET`、`POST /api/v1/ops/operator-users`	營運帳號列表、新增	營運管理者
`PUT /api/v1/ops/operator-users/{operatorUserId}/roles`	設定營運帳號的角色	營運管理者
`GET /api/v1/ops/checkouts`	以結帳單編號或會員查詢	所有角色
`GET /api/v1/ops/checkouts/{checkoutId}`	結帳單完整詳情	所有角色

需求 3.13 未列出「新增分類」的權限，第一版暫由營運管理者負責。

第一個營運管理者帳號由應用程式啟動時建立：資料庫中還沒有任何營運帳號時，以設定值 `marketplace.auth.initial-operator.username`（預設 `admin`）與 `marketplace.auth.initial-operator.password` 建立，角色為營運管理者，於第一次登入後須修改密碼。初始密碼於部署時以環境變數提供，不放入程式庫；沒有提供時不建立帳號，只記錄一筆警告。已有營運帳號後，這兩個設定值不再有作用。設定方式見 `backend/README.md`。

3.5 金流回呼

方法與路徑	用途
`POST /api/v1/webhooks/payment-gateway`	接收模擬金流的付款結果通知

標頭	說明
`X-Gateway-Timestamp`	送出時間，Unix 秒數
`X-Gateway-Signature`	以共用密鑰對「時間戳記 + `.` + 請求內容」計算的 HMAC-SHA256，十六進位表示

平台的處理：

1. 驗證簽章；時間戳記與目前時間相差超過 5 分鐘則拒絕，防止重送攻擊
2. 以事件編號判斷是否處理過，處理過則直接回應 200
3. 依事件更新付款狀態，回應 200；金流收到 200 以外的回應會重送
4. 若找不到對應的付款（商家交易編號不存在），仍回應 200 以停止重送，並記錄為警告日誌。這種情況屬於對帳差異中的「金流方有紀錄，平台沒有」，由金流對帳任務正式處理（需求 3.5）

4. 模擬金流

4.1 介面

方法與路徑	用途
`POST /gateway/v1/payments`	付款；以商家交易編號辨識重複請求
`GET /gateway/v1/payments/{merchantReference}`	依商家交易編號查詢交易結果

方法與路徑	用途
`GET`、`PUT /gateway/v1/admin/behavior`	查詢與設定異常行為，供測試與壓測使用

所有呼叫須帶 `X-Api-Key` 標頭。

退款、撥款、每日交易明細在對應的階段補上。在此之前，付款模組收到「要求自動退款」事件（使用者故事 P4）時只發出告警，由平台營運處理。

4.2 測試用付款代碼

代碼	行為
`tok_success`	立即回應成功，並送出成功的回呼
`tok_fail`	立即回應失敗，並送出失敗的回呼
`tok_async`	立即回應處理中，數秒後交易成功並送出回呼
`tok_timeout`	不在平台的逾時時間內回應；交易實際上成功，之後送出回呼
`tok_async_fail`	立即回應處理中，數秒後交易失敗並送出回呼

`tok_timeout` 用來重現使用者故事 P3。

付款處理中的結帳單不會被取消，所以無法以付款代碼讓「回呼到達時結帳單已取消」穩定發生。P4 在第一版只會因為取消與發起付款同時發生而出現，以平台的模組測試與併發測試驗證（《設計_006_測試計畫》5.2）。

4.3 可設定的異常行為

設定	說明
`latencyMillis`	每個請求額外的延遲
`failureRatePercent`	`tok_success` 也隨機失敗的比例
`duplicateWebhookPercent`	回呼重複送出的比例
`webhookDelayMillis`	回呼的延遲

全部預設為 0，只在壓測或特定測試中開啟。

4.4 平台呼叫金流的設定

項目	設定
連線逾時	1 秒
回應逾時	3 秒
逾時時	付款維持處理中，交由回呼或付款結果查詢任務確認
重試	連線失敗時可重試，因為金流以商家交易編號辨識重複請求，不會重複扣款

熔斷等保護機制在可觀測性與併發階段加入。

4.5 模擬金流的資料表

模擬金流的資料庫只有一個 schema `gateway`。

`gateway_transaction`：交易

欄位	型別	限制	說明
`id`	`uuid`	主鍵	金流方的交易編號
`merchant_reference`	`uuid`	與 `type` 組成唯一	平台送來的商家交易編號
`type`	`text`	`PAYMENT`；之後加入 `REFUND`、`PAYOUT`	
`amount`	`bigint`	大於 0	
`payment_token`	`text`	必填	測試用付款代碼
`status`	`text`	`PROCESSING`、`SUCCEEDED`、`FAILED`	
`created_at`	`timestamptz`		
`completed_at`	`timestamptz`	可為空	

`webhook_delivery`：回呼的送出紀錄

欄位	型別	限制	說明
`id`	`uuid`	主鍵	同時作為回呼的事件編號
`transaction_id`	`uuid`	外鍵 → `gateway_transaction`	
`event_type`	`text`	`PAYMENT_SUCCEEDED`、`PAYMENT_FAILED`	
`status`	`text`	`PENDING`、`DELIVERED`	
`attempt_count`	`integer`	預設 0	
`next_attempt_at`	`timestamptz`		下一次送出的時間，依退避間隔遞增
`last_response_status`	`integer`	可為空	平台最後一次的回應狀態碼
`created_at`	`timestamptz`		

重複回呼以「同一個事件編號送出多次」實現，平台以事件編號去除重複。

5. 對資料庫設計的影響

撰寫本文件時發現《設計_004_資料庫設計》需要以下補充，已套用於設計_004 1.1：

資料表	補充	原因
`shipping_address`	新增 `deleted_at`	收件資訊可刪除，以標記方式處理
`checkout`	新增 `request_hash`	判斷相同冪等鍵是否搭配了相同的請求內容
`payment`	新增 `idempotency_key`、`request_hash`；`(checkout_id, idempotency_key)` 唯一	發起付款需要冪等鍵
新增 `payment.received_gateway_event`	`event_id`（主鍵）、`event_type`、`merchant_reference`、`received_at`、`trace_id`	金流回呼以事件編號去除重複
`seller_user`、`operator_user`	新增 `must_change_password`	以初始密碼建立的帳號須先修改密碼

6. 版本紀錄

版本	日期	說明
1.0	2026-10-14	初版定版，涵蓋第一版範圍
1.1	2026-10-15	更正 4.2：`tok_timeout` 無法重現 P4；4.1 補充第一版收到自動退款要求時只發出告警；3.2 購物車標示超過結帳上限的項目
1.2	2026-10-15	1 規格檔的 tag 改為「使用對象-模組」；2.4 新增 `UNSUPPORTED_REQUEST`、`INTERNAL_ERROR`；2.7 補充登入失敗、同時換發、登出與修改密碼的規則；3.4 第一個營運管理者的帳號